

통 보

1. 제 목 : 망간자료전송시스템 운영방안 개선 필요
2. 소관부점 : 정보시스템실(정보보안부)
3. 내 용 :

가. 업무개요

정보시스템실(정보보안부)은 「업무분장세칙」 제8조에 따라 정보보안 업무를 총괄하고 있고 개인정보 노출 점검, 개인정보의 기술적 보호 조치 등 개인정보 보호 및 유출방지와 관련한 업무 전반을 수행하고 있다.

나. 관계 법령·내규 및 판단 기준

「국가 정보보안 기본지침」 제40조에 따르면 각급기관의 장은 분리된 내부망과 기관 인터넷망간 자료전송을 위한 접점이 불가피한 경우, 내부망 자료를 기관 인터넷망으로 전송 시에 부서 분임정보보안담당관¹⁾ 또는 결재권자의 사전 또는 사후 승인절차를 마련하는 사항 등을 포함한 보안대책을 수립·시행하여야 한다고 되어있고,

「정보보안업무실무요강」 제37조에 따르면 정보보안담당관²⁾은 정보

1) “분임정보보안담당관”은 「정보보안업무실무요강」 제2조 정의에 따라 부점의 정보보안업무를 수행·총괄하는 각 부점의 장을 지칭함

통신망을 구축할 경우 내부망과 인터넷망을 분리·운영하도록 하여야 하고 내부망과 인터넷망 간 안전한 자료전송 대책 등을 포함한 보안 대책을 수립·시행하여야 한다고 되어있다.

이에 따라 정보보안부장(정보보안담당관)은 업무망 PC(이하 “업무망”이라 한다)에서 기관 인터넷망 PC(이하 “외부망”이라 한다)로 자료전송 시 담당 부점의 장 또는 결재권자의 사전, 사후 승인절차를 마련하고 해당 절차를 체계적으로 관리하여 업무망과 외부망 간 안전한 자료전송을 위해 각별한 노력을 기울여야 한다.

다. 감사결과 확인된 문제점

그런데 공사 업무망과 외부망 간 자료전송 시 반드시 사용해야 하는 ‘망간자료전송시스템’의 운영 실태를 점검한 결과 다음과 같은 문제점이 확인되었다.

‘망간자료전송시스템’은 업무 담당자가 업무망에 있는 자료를 외부망으로 전송하고자 할 때에는 관리자의 결재(승인)를 받도록 되어 있고 전송하고자 하는 자료에 개인정보가 포함되어 있지 않은 경우 자료 전송 후 직근상급자의 사후결재(승인)를 받을 수 있도록 되어 있는 반면, 개인정보가 포함된 자료의 경우 업무 담당자가 개인정보의 내용 및 자료전송 사유를 기재하여 직근상급자의 사전결재(승인)를 받은 후에야 외부망으로 자료 전송이 가능하도록 되어있다.

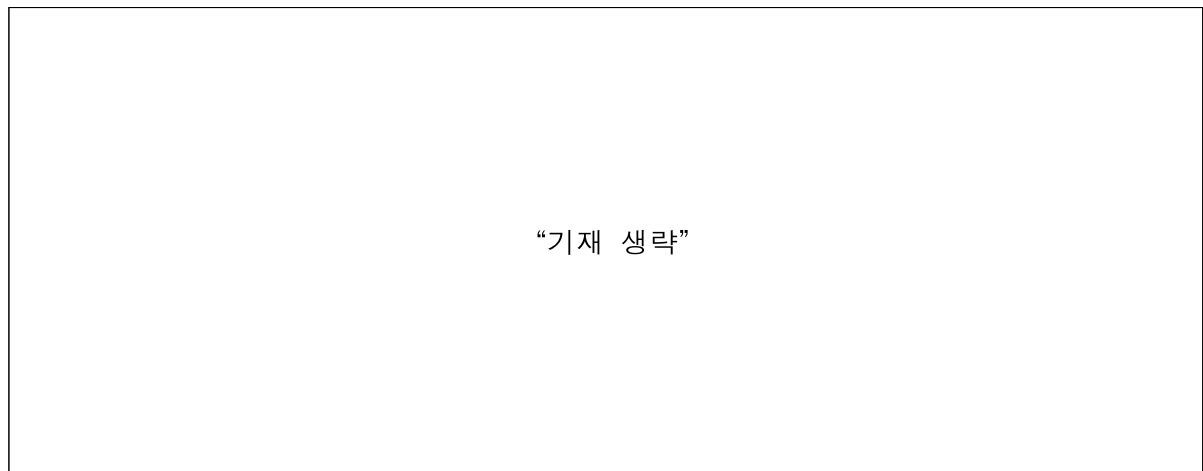
관리자의 사후결재 절차를 살펴보면, 직원이 업무망에서 외부망으로 자료

2) “정보보안담당관”은 「정보보안업무실무요강」 제2조 정의에 따라 정보보호최고책임자의 지휘·감독 하에, 정보보안업무 수행을 전담하는 부점의 장(정보보안부장)을 지칭함

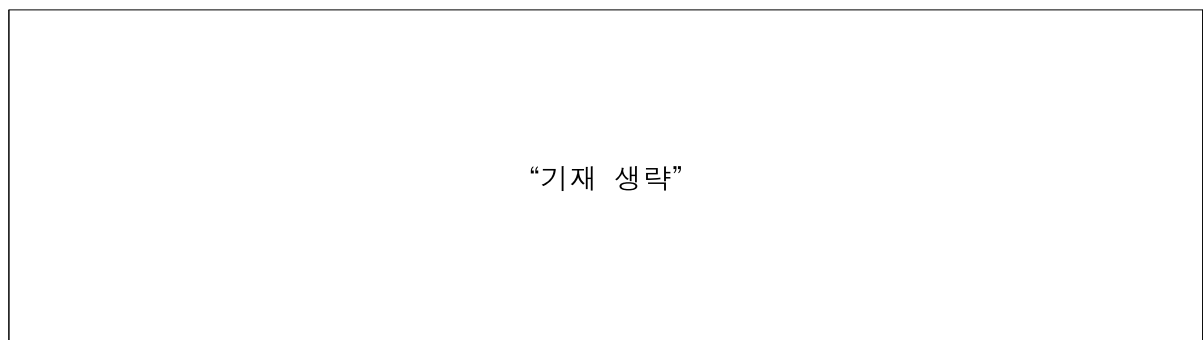
전송 시 ‘망간자료전송시스템’ 화면에서 [그림 3]과 같이 “사후결재”를 선택할 수 있게 되어 있으며, 업무담당자가 “사후결재”를 선택하고 자료를 전송하게 되면 해당 자료는 개인정보를 포함하지 않은 경우에 한해 즉시 외부망으로 전송되고 이후 관리자는 해당 파일 전송 건에 대해 결재(확인)를 할 수 있도록 되어있다.

또한, ‘망간자료전송시스템’ 화면 밖에서도 전송대상 파일을 선택하면 상기 절차 없이 [그림 4]와 같이 외부망으로 파일을 간단히 전송할 수 있는 항목이 표시되고 해당 항목 선택 시 상기 절차와 같이 즉시 자료 전송이 가능한 것으로 파악되었다.

[그림 3] ‘망간자료전송시스템’ 사후결재 선택 화면

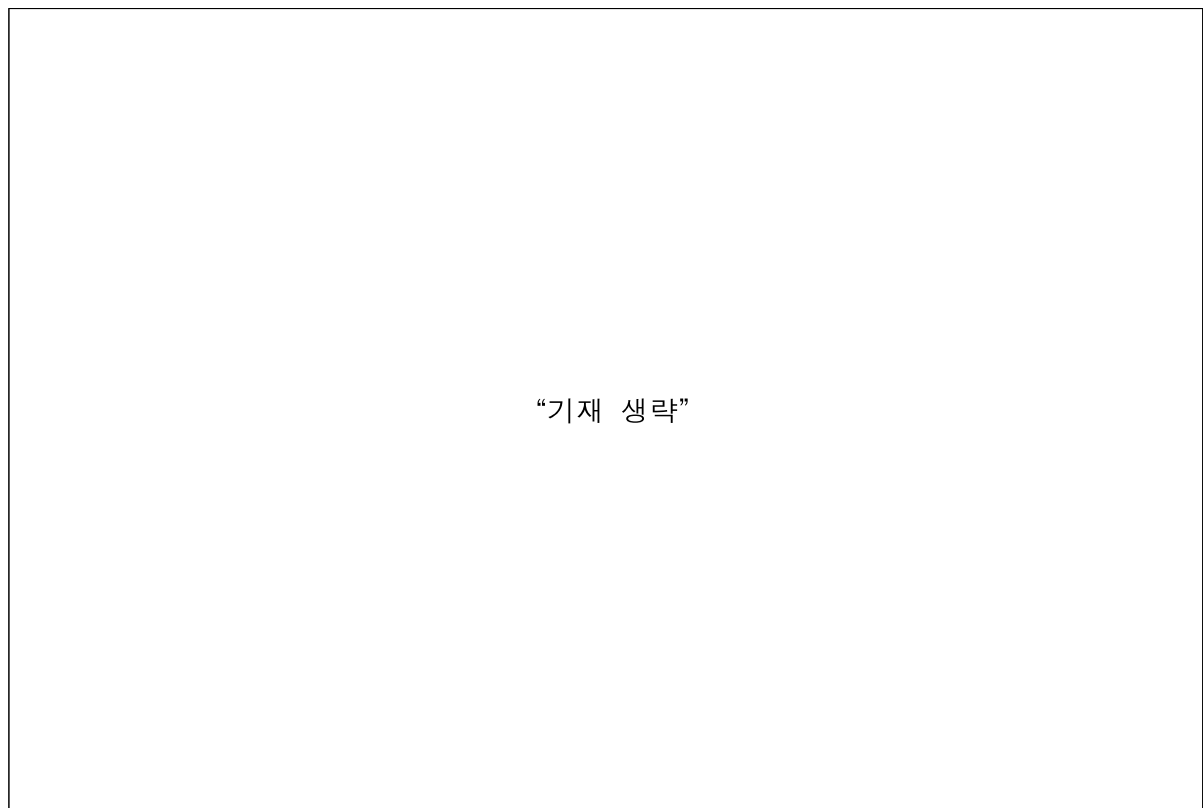


[그림 4] ‘망간자료전송시스템’ 화면 外 파일 전송 가능 화면



단, 이 경우 관리자의 사후확인 절차가 전제되는데 관리자는 ‘망간 자료전송시스템’ 화면에서 자료전송 목록을 확인할 수 있고 전송 목록에서 파일을 클릭하면 [그림 5]와 같이 “승인”, “거절”이라는 항목을 선택할 수 있게 되어있다.

[그림 5] 관리자의 결재(사후확인) 화면



그러나 사후확인 후 관리자가 “거절” 항목을 선택해도 그 이력만이 관리될 뿐 이미 전송된 자료의 회수는 불가할 뿐만 아니라 관리자가 “승인” 또는 “거절” 항목을 선택하지 않는다고 해도 아무런 제한사항이 없어 실제 대다수의 관리자는 업무망에서 외부망으로 전송된 파일에 대하여 위와 같이 사후확인³⁾을 하지 않고 있었다.

3) 관리자가 “승인” 또는 “거절” 선택 시 사후확인 란에 “승인” 또는 “거절”로 표기되며, 아무런 확인 조치를 하지 않을시 사후확인 란은 공란 상태로 지속 유지됨

실제로 2023. 9. 1.~ 9. 30. 기간 동안 망간자료전송시스템 상 관리자의 실제 사후확인 여부를 살펴본 결과, [표 10]과 같이 사후확인을 전제로 업무망에서 외부망으로 전송된 파일 총 개 중 관리자가 “승인” 또는 “거절” 항목을 선택하여 사후확인을 한 경우는 단 개에 불과하였고 사후확인을 하지 않은 경우는 건으로 대다수를 차지하였다.

[표 10] 최근 1개월 간 망간전송된 자료 중 사후확인 절차 이행 현황

(단위: 건)

대상기간	망간 전송자료	관리자 사후확인	관리자 미확인
------	---------	----------	---------

“기재 생략”

게다가, 관리자가 사후확인을 하지 않은 채 30일이 경과하면 망간자료 전송시스템 상 외부망으로 전송된 파일의 리스트만 남고 실제 전송 파일은 삭제되어 관리자가 전송된 파일의 내용을 확인할 수 없었다.

만약 업무 담당자가 중요자료를 실제 내용과는 다른 제목으로 파일명을 변경하고 상시 사후확인 절차를 이용하여 해당 자료를 외부망으로 반출하게 될 경우, 관리자는 실제로 어떠한 업무 자료가 무단 반출되었는지 알 수 없는 심각한 상황이 발생할 수 있어 이에 대해서는 신속한 보완 조치가 필요하다고 보여진다.

[소관부점 의견] 정보시스템실(정보보안부)은 감사결과 이견을 제기하지 않았으며 지적받은 사항을 포함하여 망간자료전송시스템 전반을 면밀히 검토하여 취약점을 분석하고 신속히 조치를 이행하겠다고 답변하였다.

4. 조치할 사항

정보시스템실장(정보보안부장)은 업무망에서 외부망으로 자료 전송 시 실제 사후확인이 이루어지지 않고 있는 현행 시스템 상의 취약점을 포함하여 망간자료전송시스템 전반을 점검하고 확인된 문제점에 대해 신속하게 개선 방안을 마련하시기 바랍니다. (통보)